Greenfield University: Risk Assessment and BCP Response

Done by: Jeffrey Harris, Aayush Ramkumar, SK Narendhran, KB Aditya

1. Risk Identification:

A. Technology Risks

- Lateral Malware Propagation: Risk of ransomware traversing compromised network segments from CampusLearn file servers to the functioning Student Information System or Active Directory.
- Backup Repository Contamination: Risk that the 6 hour incremental snapshots or the 24 hour full backup contain dormant ransomware payloads, preventing safe restoration.
- Question Bank Data Loss or Encryption: Encryption of the primary question bank repository without immediate access to unencrypted offline copies.

B. Operational Risks

- Academic Timetable Breakdown: Inability to examine 4000 students scheduled over the next 48 hours, threatening term completion, graduation timelines, and grade recording.
- Physical Campus Bottlenecks: On campus computer laboratories have limited seating capacity and cannot physically or technically accommodate 4000 displaced online test-takers.
- Absence of Approved Manual Workarounds: Lack of a pre-approved, standardized protocol for conducting examinations manually or via offline channels during a platform outage.

C. People Risks

- Staff Fatigue & Operational Panic: IT engineers, exam proctors, and faculty operating under extreme crisis pressure without defined shift rotations.
- Student Distress & Anxiety: Severe academic uncertainty among students awaiting degree certifications, leading to anxiety, agitation, and potential campus protests.
- Phishing & Social Engineering Vulnerabilities: Increased susceptibility of faculty and students to secondary phishing or extortion scams during system chaos.

D. Communication Risks

- Information Vacuum & Conflicting Messaging: Absence of coordinated, centralized communications leading to contradictory advice from individual faculty members to students.
- Social Media Leak Escalation: Student posts and leaks rapidly gaining traction online, creating public panic before official statements are issued.

E. Reputational Risks

- Institutional Brand & Accreditation Damage: Media coverage framing the university as technologically vulnerable and poorly prepared, impairing future admissions, rankings, and alumni giving.
- Extortion Perceptions: Severe public criticism and ethical backlash if leadership yields to criminal extortion demands.

F. Legal & Compliance Risks

- Data Privacy Violations: Potential data exfiltration of student records violating regional data protection regulations, leading to statutory investigations and fines.
- Sanctions & Ransom Legality: Potential legal liabilities associated with paying cryptocurrency ransoms to sanctioned or illegal entities.
- Contractual Accreditation Breaches: Failure to deliver scheduled degree examinations within mandated academic windows, risking regulatory reprimands or student litigation.

G. Third-Party Dependency Risks

- Hosting Provider Latency: Dependency on third-party cloud hosting vendors with slow ticket turnarounds or rigid Service Level Agreements.
- Forensic & Insurance Delays: Procedural delays awaiting external incident response forensics teams and cyber-insurance underwriters.

2. Risk Treatment Plan

Risk Description	Strategy	Actionable Controls & Treatment Measures	Responsible Owner	Residual Risk
Backup corruption / infection	Reduce	Isolate backup data into an air-gapped sandbox. Run cryptographic parity and hash comparisons on the 24-hour backup before restoring to clean VMs.	IT Infrastructure Lead	Medium

Risk Description	Strategy	Actionable Controls & Treatment Measures	Responsible Owner	Residual Risk
4,000-student exam outage	Mitigate	Decisively refuse ransom payment. Declare a 24-hour examination suspension for Day 1. Deploy contingency offline/proctored exams for Day 2.	Vice-Chancellor & Academic Dean	Medium
Lateral spread to SIS	Reduce	Sever all routing paths and firewall links between CampusLearn and the SIS. Isolate SIS into a read-only environment and force credential rotation.	IT Security Lead	Low
Public & media escalation	Reduce	Funnel all updates exclusively through the university website status banner and official email. Release a clear holding statement within 90 minutes.	Communications Lead	Low
Legal & regulatory liability	Avoid	Avoid ransom payment to eliminate extortion sanctions risks. Transfer liability by notifying cyber-insurance carriers and engaging external breach counsel.	Legal Counsel & Finance Lead	Low
Student panic & staff fatigue	Reduce	Publish a guaranteed "no academic penalty" pledge. Establish a student support phone line. Implement mandatory 8-hour shift rotations for IT staff.	Dean of Students & HR Lead	Low
Third-party service delays	Transfer	Activate priority breach support clauses with the hosting provider. Engage on-call digital	Procurement & IT Lead	Medium

Risk Description	Strategy	Actionable Controls & Treatment Measures	Responsible Owner	Residual Risk
		forensic incident responders.		

3. Mini Business Impact Analysis (Mini-BIA)

Core Recovery Principle: RTO + WRT <= MTD

Business Process	Main Dependencies	Impact if Unavailable	RTO	RPO	Priority	Approved Continuity / Workaround Strategy
Online Examination Delivery	CampusLearn LMS, Question Banks, Network Infrastructure	Inability to evaluate 4,000 students; semester invalidation; graduation delays.	12 Hours	0 Hours	Critical	Suspend Day 1 exams. Request faculty provide offline master exam papers. Prepare paper-based hall testing and encrypted PDF distribution for Day 2.
Student Record & Auth Access	Student Information System (SIS), Directory Services	Inability to verify student registration, course completion, or grade recording.	4 Hours	1 Hour	Critical	Keep SIS isolated on an independent, read-only network segment to support verification without

Business Process	Main Dependencies	Impact if Unavailable	RTO	RPO	Priority	Approved Continuity / Workaround Strategy
						ransomware contamination.
Institutional Communications	University Public Website, Institutional Email	Loss of operational control, widespread misinformation, rumor spread on social media.	1 Hour	15 Mins	Critical	Route all announcements through the untouched primary website homepage and verified faculty/student email addresses.
Course Content & Assignment Archiving	CampusLearn File Storage, Cloud Document Repositories	Students unable to view course notes or past work; grading bottlenecks.	48 Hours	24 Hours	Medium	Freeze pending assignment deadlines. Instruct faculty to accept submissions via direct email attachments.
Tuition & Payroll Processing	Finance ERP, External Banking Interfaces	Delays in processing staff salaries or receiving student payments.	24 Hours	4 Hours	High	Transition to secure, out-of-band banking portals managed directly by authorize

Business Process	Main Dependencies	Impact if Unavailable	RTO	RPO	Priority	Approved Continuity / Workaround Strategy
						d finance staff.

4. 24-Hour BCP Response Plan

Incident Response Team Structure

- Incident Commander: Vice Chancellor
- Deputy Commander: Academic Registrar Dean
- IT and Recovery Lead: CIO
- Communications Lead: Director of Public Relations
- Legal & Finance Lead: General Counsel & Chief Financial Officer

Chronological Response Timeline

Emergency Declaration & Decisive Mandate

- VC Executive Decision:
    - Formally reject payment of the cryptocurrency ransom.
    - Formally activate the Business Continuity Plan.
    - Declare an official 24 hour moratorium on all online examinations.
- Immediate IT Containment:
    - The network isolates the CampusLearn database clusters and infected file servers.
    - Verify strict logical separation between CampusLearn and the functional Student Information System.
    - Capture volatile memory dumps and system log snapshots for forensic investigators.

Stakeholder Notification & Investigative Triaging

- Crisis Communications Broadcast:
    - Publish an urgent notice on the university homepage and dispatch emails to all students:
    - Distribute a press holding statement reframing the incident as proactive containment while safeguarding student academic integrity.
- Legal & Insurance Engagement:
    - File formal claim notification with the university's cyber-insurance underwriter.
    - Retain specialized third-party digital forensics and incident response specialists.

- Backup Integrity Verification:
    - Mount the 24 hour full backup and 6 hour incremental snapshots within an air-gapped sandbox to confirm absence of encryption scripts or backdoors.

Recovery Scaffolding & Academic Workaround Engineering

- Academic Contingency Formulation:
    - Deans instruct department chairs to assemble offline question papers directly from faculty.
    - Provision physical lecture auditoriums and sports complexes for invigilated paper based exams scheduled for Day 2.
- Clean Environment Provisioning:
    - Spin up hardened virtual server instances in a secure cloud tenant.
    - Initiate restoration of the verified clean 24 hour database backup into the new staging environment.
- Faculty & Staff All-Hands:
    - Conduct an all faculty briefing through email telling them exam reschedule policies, grading accommodations, and proctoring rosters.

Testing, Verification & Phased Resumption

- System Verification & Integrity Testing:
    - Complete data restoration; reconcile student course enrollments against the uncorrupted SIS.
    - Execute rapid vulnerability scans and penetration checks on the restored platform.
- Release of Rescheduled Examination Timetable:
    - Email the complete revised examination calendar to all 4000 affected students.
    - Announce hybrid delivery options.
- Executive Review & BCP Stand-Down:
    - IRT meets to evaluate stability, confirm operational readiness, and transition from emergency mode to heightened monitoring.
    - Document all actions and timelines into the official Incident Report Template for regulatory audits and post-mortem continuous improvement.

6. Disaster Recovery Plan (DRP): Technical System Restoration

While the BCP manages operational continuity, academic scheduling workarounds, and stakeholder communication, this Disaster Recovery Plan (DRP) defines the specific technical procedures executed by the IT and Security teams to isolate, sanitize, reconstruct, and restore technical infrastructure to full production status.

6.1 Disaster Recovery Objectives & Metrics

Disaster Recovery Team (DRT) Responsibilities

Role	Primary Responsibility	Key Focus Areas
DR Lead / Technical Commander	Chief Information Officer	Overall orchestration, escalation management, cutover authorization
Systems & Storage Administrator	Infrastructure Engineering	Backup extraction, hypervisor rebuilding, compute staging
Network & Security Engineer	Cyber Defense & Telecommunications	Firewall isolation, micro-segmentation, lateral defense, EDR deployment
Database Administrator (DBA)	Data Architecture	Database schema verification, table integrity checks, log reconstruction
Applications Specialist	Enterprise Systems	CampusLearn LMS application deployment, web server configuration, SIS sync

Key Technical Recovery Objectives

- Recovery Point Objective (RPO): Maximum 24 hours (governed by the last full backup verified clean).
- Recovery Time Objective (RTO): 12 hours from infrastructure staging to LMS service viability.
- Work Recovery Time (WRT): 4 hours for end-to-end data validation, integrity checks, and user acceptance testing prior to cutover.

- Core Operational Constraint: $RTO(12h) + WRT(4h) \leq MTD(24h)$ for critical examination infrastructure.

6.2 Phase 1: Technical Isolation, Evidence Preservation & Containment (Hours 0 – 2)

Network Segmentation & Micro-Isolation

- Disconnect all CampusLearn virtual network interfaces (vNICs) at the hypervisor level.
- Disable all external routing, VLAN trunks, and VPN gateways linked to infected subnets to stop lateral spread to the Student Information System (SIS) and active identity infrastructure.
- Restrict active administrative accounts; enforce emergency revocation and credential reset across all elevated domain and database service accounts.

Digital Forensics & Evidence Preservation

- Take snapshot memory dumps (RAM) of infected virtual machines prior to power-off for forensic attribution.
- Export security perimeter logs, DNS sinkhole telemetry, firewall logs, and hypervisor system access logs to an immutable write-once read-many (WORM) storage bucket for insurer and regulatory auditing.
- Preserve encrypted payload binaries and ransom notes in an isolated diagnostic quarantine for hash identification and key discovery.

6.3 Phase 2: Secure Infrastructure Provisioning & Environment Staging (Hours 2 – 6)

Isolated Recovery Environment (Clean Room)

- Provision a completely sanitized, air-gapped staging Virtual Private Cloud (VPC) or clean on-premises hypervisor cluster physically separate from compromised networks.
- Re-deploy pristine OS baseline images from verified golden master templates with hardened CIS (Center for Internet Security) benchmarks.
- Apply immediate zero-day kernel and hypervisor security patches to eliminate the vulnerability that allowed initial entry.

Endpoint Detection and Access Hardening

- Deploy modern Endpoint Detection and Response (EDR) agents in aggressive blocking mode on all newly staged nodes.

- Configure strict zero-trust network access (ZTNA): deny all default inbound/outbound traffic; whitelist only necessary internal ports (e.g., specific DB connections between application and database tiers).

6.4 Phase 3: Backup Parity Verification & Data Restoration (Hours 6 – 14)

Backup Verification & Malware Scanning

- Mount the 24-hour full backup repository in a read-only sandboxed virtual environment.
- Perform automated signature, file extension, and behavioral heuristics scans across the backup image to verify absence of encrypted blocks or dormant trojans/payloads.
- Inspect the 6-hour incremental backup snapshots; compare file modification timelines with the initial anomaly detection timestamp (8:30 AM). If incremental snapshots show signs of tampering, fail back exclusively to the verified 24-hour baseline.

Database Reconstruction & Schema Recovery

- Restore the core database instance into the clean staging environment.
- Verify table structure and database integrity using database consistency checkers (e.g., DBCC / integrity validation scripts).
- Rebuild encrypted database indexes and execute checksum validations to ensure zero block-level corruption.

Question Bank & Course Data Reconstruction

- Re-link the primary examination question bank repository.
- Where incremental delta files were infected, cross-reference question bank tables with uncorrupted offline master copies obtained from faculty departments.

6.5 Phase 4: Integration, Reconciliation & Security Validation (Hours 14 – 18)

Student Information System (SIS) Re-Integration

- Establish an authenticated, encrypted micro-tunnel between the newly restored CampusLearn staging environment and the functional SIS database.
- Run bidirectional synchronization reconciliation to confirm student enrollments, exam registrations, and profile metadata match live SIS records without record dropping.

Penetration Testing & Smoke Vulnerability Scans

- Execute automated vulnerability assessment and vulnerability remediation scans on the restored web application and database tiers.
- Run simulated load testing to confirm that system throughput can support simultaneous access by student cohorts under exam conditions.

6.6 Phase 5: Phased Production Cutover & Failback (Hours 18 – 24)

User Acceptance Testing (UAT)

- Assemble designated department leads and faculty test users to execute end-to-end dummy examination sessions (login, paper display, timer tracking, and answer submission).
- Verify proper functionality of exam proctoring logs and auto-save mechanisms.

DNS & Production Traffic Rerouting

- Update internal and external DNS pointers, routing student domain traffic from the old compromised nodes to the newly hardened, clean production environment.
- Enable Multi-Factor Authentication (MFA) prompts for all faculty, proctor, and student logins.

Continuous Monitoring & Stand-Down Handover

- Activate 24/7 hypercare monitoring: continuous SOC telemetry oversight, heightened alerting for anomalous credential spikes, and real-time database query inspection.
- Formally notify the Incident Response Team (IRT) that technology recovery is complete and systems are operational for academic exam rescheduling.
- Complete technical post-incident documentation detailing recovery timelines, root-cause vulnerability analysis, and permanent infrastructure fortification steps.